CtrlPay — Security Self-Assessment Report (安全自评报告)

Project: CtrlPay — *Stop Paying Blindly. Let AI Control the Flow.* **Topic:** A · Proactive Defensive Personal-Finance Agent **Platform:** Web sandbox (Next.js 14 App Router, AI SDK v4 client stream + Groq Chat Completions / GPT-OSS 120B) **Scope note:** CtrlPay is a **sandbox**. It moves **no real funds**. Every "balance", "vault", "escrow" and "reward" is a labelled local ledger bucket. This report states both the controls we implement **and** the residual risk we do not claim to remove.

10.1 Security Control Matrix

(1) Human Confirmation & Tiered Autonomy — 人工确认与分级授权

- **Layer:** Application / Authorization (应用层 · 授权层)
- **Implementation**
  - Master Autonomy Switch is **default OFF** (`lib/store.ts`).
  - Four permission tiers **T0–T3** (`lib/permissions.ts` , `TOOL_TIERS`).
  - `assertTier()` runs **server-side** before every tool executes (`app/api/chat/route.ts`) **and** again in the proposal decision route (`app/api/proposals/[id]/decision/route.ts`).
  - The client-submitted autonomy object is **schema-validated** (`TierStateSchema` , `lib/types.ts`). A malformed payload receives HTTP **400** and can never reach `assertTier()` or silently enable a tier.
  - **T3 (Quarantine / Escrow / Sweep)** additionally requires a per-action click authorization ref matching `USER_CLICK_APPROVE_PROPOSAL_*` (`lib/permissions.ts` → `CLICK_AUTH_RE`). Proposal **creation** is preparation only; the decision itself is gated.
  - Dual Mandates: the **User Spending Limit** and the **AI Mandate Limit** (`maxLockAmountRM` , `maxLockDurationDays`) are enforced inside `validateEscrowFloor` and proposal creation.
  - **NEEDS** categories can never be locked; escrow is capped by the **40 % rule** and a **duty-of-care daily survival floor** (RM 15). The proposal API independently rejects a **NEEDS-category Quarantine**, even when a caller bypasses the LLM tool schema.
- **Verification**
  - `tests/permissions.test.ts` — tier gating, master-switch off blocks T1–T3, T3 without a valid click ref is rejected.
  - `tests/quant-engine.test.ts` — NEEDS rejected from escrow; 40 % cap and RM 15 floor enforced; AI mandate violation rejected.
  - `tests/tool-resolution.test.ts` — every contract card path resolves its tool call.
  - `tests/red-team.test.ts` — route-level T-01 (Master OFF → **403** + **BLOCKED** audit), malformed autonomy → **400**, direct NEEDS-Quarantine → **400**, unknown escrow category → **400**.
  - Live demo: toggle the master switch; attempt a T3 action without clicking → a **BLOCKED** audit entry with a reason-coded `actionType` (e.g. `T3_GATE_REJECTED_MASTER_AUTONOMY_OFF`) is written.
- **Residual risk:** the sandbox session is **not strongly authenticated** (a signed cookie stands in for a real login). Production needs real identity, **step-up authentication** and device binding. A user can still approve a harmful-but-allowed contract; this is mitigated by the floors and caps, not eliminated. In the

sandbox, the Master Switch, tier toggles and AI mandate are **user-owned client state** sent with each request: the server validates their shape and defaults to OFF when absent, but a user-controlled client can assert its own settings — production must bind them to server-side account settings. Proposal status/replay protection is **in-memory**: a stateless cold start still re-verifies the HMAC signature, but it cannot know whether another instance already settled the proposal; production needs a durable, tenant-scoped proposal table.

(2) Network, Environment & Pop-up Safety — 网络环境与弹窗安全

- **Layer:** Platform / Transport (平台层 · 传输层)
- **Implementation**
  - **HTTPS-only** deployment assumption; `Strict-Transport-Security` shipped.
  - Strict **CSP** with `default-src 'self'`, `object-src 'none'`, `frame-ancestors 'none'`, `base-uri 'self'`, `form-action 'self'` (`next.config.mjs`).
  - **Zero third-party ad/tracking scripts**; `connect-src 'self'`.
  - **No pop-up ads** by design (a documented brand/ethics decision).
  - **Wi-Fi detection and malicious pop-up blocking are Platform-Layer controls** (OS/browser). A web app has no OS-level network or pop-up interception permission, so these are explicitly documented as **outside the app's authority boundary**.
- **Verification**
  - `tests/compliance.test.ts` asserts the CSP directives, that no remote script/connect origin is whitelisted, and that the hardening headers are present.
  - Manual: inspect response headers; Network tab shows no third-party requests.
- **Residual risk:** a web app cannot detect a hostile Wi-Fi network or a malicious pop-up from another app; the user relies on OS/browser protection. A mobile production build should add **certificate pinning**.

(3) Full-Lifecycle AI Audit Logging — AI 全流程审计

- **Layer:** Audit / Accountability (审计层)
- **Implementation**
  - Append-only, **hash-chained** log (`lib/audit-logger.ts`) with fields `logId, timestamp, actor, actionType, permissionTier, data_accessed (field names only), authorization_ref, proposal_hash, status`.
  - An **"immutable trace drawer"** for users (`components/audit-drawer.tsx`) with a **chain-verified** indicator.
  - Every tool call, block, decision and clock mutation writes an audit entry; the post-LLM number verifier logs its own PASSED/BLOCKED record.
  - Authorization refusals are recorded with status **BLOCKED** (not `DECLINED`) and a reason-coded `actionType`, e.g. `T3_GATE_REJECTED_MASTER_AUTONOMY_OFF` or `T3_GATE_REJECTED_T3_REQUIRES_EXPLICIT_USER_CLICK`.
- **Verification**
  - `tests/audit-logger.test.ts` — `verifyChain()` detects tampering; an edited entry breaks the chain.

- Demo: open the Audit Drawer and show `data_accessed`, `authorization_ref` and the chain-verified badge.

- **Residual risk:** the sandbox log lives in server memory / browser `localStorage` and can be wiped by the operator. Production requires **WORM / append-only storage with external anchoring**.

(4) Three-Stage Privacy & Hallucination Guardrails — 三段式隐私与幻觉防护

- **Layer:** Data / Model (数据层 · 模型层)
- **Implementation**
  - **(a) Pre-LLM PII masking** of account numbers, IC, phone numbers and person names (`lib/privacy-guard.ts`).
  - **(b) Per-user tenant isolation** — `userId` comes **only** from the signed session cookie, never the request body or the LLM (`lib/session.ts`).
  - **(c) Zod `.strict()` schemas + a post-LLM RM number verifier** tied to engine/ledger outputs (`verifyNumbers`); unknown figures are flagged and the turn is audit-logged as `NUMBER_VERIFIER_BLOCKED`.
  - **Receipt OCR images are never written to disk** — processed in memory, discarded after structured extraction + user confirmation. The Tesseract worker, WebAssembly core and English language data are **self-hosted** under `public/tesseract/`, so CSP stays `script-src 'self'` with only `wasm-unsafe-eval` added for in-browser OCR.
  - **Server-side authority:** the LLM extracts intent + identifiers only; all money figures are computed by `lib/quant-engine.ts` and returned as a **signed proposal**; the LLM never sees `serverSecret`.
  - **Fail-closed secrets:** `lib/signing.ts` and `lib/session.ts` throw in production if `CTRLPAY_SIGNING_SECRET` is missing; they never fall back to the public development secret on a deployed instance.

- **Verification**
  - `tests/privacy-guard.test.ts` — PII fixtures masked (`TRANSFER TO AHMAD BIN ALI 0123456789` → `TRANSFER TO [PERSON] [ACCOUNT]`); a number-verifier test with an injected fake RM figure is rejected.
  - `tests/session.test.ts` — tenant isolation; cross-user access returns nothing.
  - `tests/proposals.test.ts` — schema violations (extra keys, NEEDS lock, a `deepLinkUrl` key) are rejected.

- **Residual risk:** regex redaction can miss unusual formats; the LLM provider still sees **redacted** transaction text; browser speech recognition may send audio to the cloud (disclosed in the UI); the verifier checks **numbers**, not the semantic correctness of advice. Groq is called directly when a Groq key is configured; otherwise the same Groq-hosted GPT-OSS model is reached through Vercel AI Gateway, pinned to the Groq provider. Groq is called statelessly: CtrlPay sends the redacted transcript on each turn and resumes T3 cards with an opaque client-supplied tool-call context. The server accepts only the selected T3 call, validates its name, and never executes client-supplied server-tool results; the actual ledger mutation still goes through the signed proposal decision route. Groq may process request data under its own API data policy; no signing secret, raw credential, receipt image or full account number is sent. The OCR/payment advisor receives only merchant, amount, category, date and budget context, never the receipt image.

(5) Identity & Student Privilege Verification — 身份与学生资格验证

- **Layer:** Identity (身份层)
- **Implementation**
  - Data-minimised **Student Email (.edu / USM) OTP** flow in the sandbox (`components/student-downgrade-drawer.tsx`).
  - **No ID / passport / face data** is collected or stored anywhere.
  - Production path: integrate a **licensed third-party eKYC provider**.
- **Verification**
  - Demo the OTP → deep-link → confirm flow.
  - Code search confirms no ID-upload endpoints or image persistence.
  - Data inventory shows only `studentEmail` and a `studentVerified` flag.
- **Residual risk:** sandbox OTP is simulated, so it proves the **flow**, not identity. Student emails can be shared or misused; production requires a licensed eKYC / institution verification partner.

(6) Safe Navigator Deep-Link & `mailto:` Execution — 安全导航与邮件草稿

- **Layer:** Execution / Integrity (执行层)
- **Implementation**
  - Hardcoded `SUBSCRIPTION_REGISTRY` **HTTPS whitelist** keyed by the `subscriptionId` enum (`lib/subscription-registry.ts`). **The LLM cannot supply a URL** — a `deepLinkUrl` key is rejected by `.strict()` .
  - `mailto:` drafts are built **client-side** from registry templates (`lib/api-client.ts` → `buildMailto`).
  - CtrlPay holds **no autonomous credentials and no OAuth write access** (no Gmail send scope).
  - External links open with `rel="noopener noreferrer"` and `target="_blank"` .
- **Verification**
  - `tests/subscription-registry.test.ts` — every deep link is HTTPS and every mailto recipient is valid.
  - `tests/proposals.test.ts` — a tool call carrying `deepLinkUrl` is rejected.
  - Code search for Gmail send scopes returns nothing.
- **Residual risk:** registry entries can go **stale** if merchants change URLs (needs a maintenance + verification process); the user can edit the draft before sending; the mail client is outside our control. One registry recipient (`membership@anytimefitness.example`) is a reserved `.example` **sandbox placeholder**; the cancellation sheet labels it **"Demo sandbox address — not a real merchant mailbox"** and it must be replaced with a verified club address before production.

10.2 Privacy-by-Default Design Rationale

> **No quantitative survey is claimed in this report.** The submission contains no survey sample size (`n`) and no willingness percentages; earlier planning templates that reserved those fields have been removed so nothing unverified is presented to judges.

CtrlPay's permission model was designed under a **Privacy-by-Default / Zero-Trust** assumption: until a user has been explicitly educated and has opted in, we assume **zero tolerance** for silent background scanning, data resale and autonomous money movement. The architecture therefore enforces the most conservative posture first and lets the user unlock capabilities one tier at a time.

Data access	Product decision	Why
(a) Gmail read-only receipt access	**Opt-in only**; read-only; structured fields only; revocable; the sandbox uses mock emails	Parsing receipts saves manual entry, but silent inbox scanning is unacceptable by default.
(b) Bank statement upload	**Not required** for any core safety feature	The sandbox ledger plus manual/receipt bookkeeping keep every feature usable without bank credentials.
(c) Real-time GPS location tracking	**Not collected**	Replaced by a time-triggered 12:00 PM summary; GPS stays on the future roadmap.
(d) IC / passport upload & facial liveness	**Not collected**	Student status is proven with a sandbox email OTP; production would use a licensed eKYC provider, never raw documents inside CtrlPay.

These decisions map directly onto enforceable controls:

- **Master Autonomy Switch default OFF** — T0 read-only analysis only until the user opts in (`lib/store.ts`).
- **T0–T3 tiered authorization** — T1 tagging, T2 drafted cancellations, T3 state changes; T3 always requires a per-action click or a passkey signature (`lib/permissions.ts`).
- **Dual mandate limits** — the user's spending limits and the AI mandate cap every contract; NEEDS categories can never be escrowed; the 40% reduction cap and the RM 15 survival floor are enforced server-side (`lib/quant-engine.ts`).
- **Every optional permission defaults to OFF** and is individually revocable in the UI; the audit log records field names only, never raw PII values.

10.2.1 Sandbox data & commercial-model disclosures

- **Registry snapshot.** Prices, cancellation links and mailto recipients in `SUBSCRIPTION_REGISTRY` are a **sandbox snapshot (last verified 2026-03-01)**. Production would synchronise them through merchant official APIs or a scheduled compliance review. The single Anytime Fitness mailto recipient uses the reserved `.example` TLD and is visibly labelled as a **demo sandbox address** in the UI; it is not presented as a real merchant mailbox.
- **Pro pricing is a hypothesis.** The Pro tier (RM 9.90/month, RM 49 student first year) is a **team business-model hypothesis**, not a live price.
- **Ethical freemium.** Every defensive control — overspend alerts, payment interception, the T0–T3 switches and the audit log — is **permanently free** and never reads the `plan` flag; `tests/compliance.test.ts` enforces this.

10.3 IP & Asset Compliance Statement

External **Behance UI links were used strictly for high-level visual inspiration and moodboarding.** We did not copy layouts, assets, illustrations or brand materials. All UI layouts, Shadcn/Tailwind components, icons (**Lucide**, open-source) and the **sandbox datasets are 100 % original or open-source licensed**, in compliance with the FinTechathon anti-plagiarism rules. Third-party merchant names in the registry are used only as descriptive labels for mock data; **no merchant logos are included**. All dependencies and their licenses are listed in `THIRD_PARTY_LICENSES.md`.

10.4 Disclosures (for judge Q&A)

- **Not a financial institution.** CtrlPay is a budgeting/protection tool. No real funds, no deposits, no interest, no investment advice. `defenseVault` is a labelled sandbox ledger bucket.
- **Model limits.** CFaR is a historical-bootstrap estimate under an independent-days assumption; the UI shows the **"limited history" warning** when data is short.
- **Demo values.** Prices, thresholds, rewards and plan pricing are sandbox configuration, to be validated with real merchants and market data before any production launch.
- **Open Banking / merchant webhooks** are represented by **mock event buttons** in the sandbox.
- **Free-tier safety.** Core safety features (quarantine, escrow floor, zombie radar, audit log, privacy guard, number verifier) **do not read the `plan` flag** — a regression test (`tests/compliance.test.ts`) enforces this, so safety is never paywalled.